

WEKK 5

INCIDENCE RESPONSE

Introduction

Incident response is an organized, strategic approach to detecting and managing cyber attacks in ways that minimize damage, recovery time and total costs.

Strictly speaking, incident response is a subset of incident management. *Incident management* is an umbrella term for an enterprise's broad handling of cyber attacks, involving diverse stakeholders from the executive, legal, HR, communications and IT teams. Incident response is the part of incident management that handles technical cybersecurity tasks and considerations.

Types of security incidents

In developing incident response strategies, it's important to first understand how security vulnerabilities, threats and incidents relate.

A *vulnerability* is a weakness in the IT or business environment. A *threat* is an entity -- whether a malicious hacker or a company insider -- that aims to exploit vulnerability in an attack. To qualify as an *incident*, an attack must succeed in accessing enterprise resources or in otherwise putting them at risk. Finally, a *data breach* is an incident in which attackers successfully compromise sensitive information, such as personally identifiable information or intellectual property.

When it comes to cybersecurity, an ounce of prevention is worth a pound of cure. Experts say organizations should fix known vulnerabilities and proactively develop response strategies for dealing with common security incidents. These include the following:

- Unauthorized attempts to access systems or data.
- Privilege escalation attacks.
- Insider threats.
- Phishing attacks.

- Malware attacks.
- Denial-of-service (DoS) attacks.
- Man-in-the-middle attacks.
- Password attacks.
- Web application attacks.
- Advanced persistent threats.

What is an incident response plan?

An incident response plan is an organization's go-to set of documentation that details the following:

- **What.** Which threats, exploits and situations qualify as actionable security incidents, and what to do when they occur.
- **Who.** In the event of a security incident, who is responsible for which tasks and how others can contact them.
- **When.** Under what circumstances team members should perform certain tasks.
- **How.** Specifically how team members should complete those tasks.

An incident response plan acts as a detailed, authoritative map, guiding responders from initial detection, assessment and triage of an incident to its containment and resolution.

How to create an incident response plan

Successful incident response requires proactively drafting, vetting and testing plans *before* crisis strikes. Best practices include the following:

1. **Establish a policy.** An incident remediation and response policy should be an evergreen document describing general, high-level incident-handling priorities.

A good policy empowers incident responders and guides them in making sound decisions when the proverbial excrement hits the fan.

2. **Build an incident response team.** An incident response plan is only as strong as the people involved. Establish who will handle which tasks, and ensure everyone has adequate training to fulfill their roles and responsibilities.
3. **Create playbooks.** Playbooks are the lifeblood of incident response. While an incident response policy offers a high-level view, playbooks get into the weeds, outlining standardized, step-by-step actions responders should take in specific scenarios. Playbook benefits include greater consistency, efficiency and effectiveness -- in both incident response and incident responder training.
4. **Create a communication plan.** An incident response plan can't succeed without a solid communication plan among diverse stakeholders. These may include the incident response, executive, communications, legal and HR teams, as well as customers, third-party partners, law enforcement and the general public.

Incident response frameworks: Phases of incident response

Rather than trying to recreate the wheel, an organization looking to build an incident response plan can refer to established incident response frameworks for high-level guidance and direction.

Well-known frameworks from NIST, SANS Institute, ISO and ISACA all differ slightly in their approaches, yet they each describe similar phases of incident response:

1. **Preparation/planning.** Build an incident response team and create policies, processes and playbooks; deploy tools and services to support incident response.
2. **Detection/identification.** Use IT monitoring to detect, evaluate, validate and triage security incidents.
3. **Containment.** Take steps to stop an incident from worsening and regain control of IT resources.

4. **Eradication.** Eliminate threat activity, including malware and malicious user accounts; identify any vulnerabilities the attackers exploited.
5. **Recovery.** Restore normal operations and mitigate relevant vulnerabilities.
6. **Lessons learned.** Review the incident to establish what happened, when it happened and how it happened. Flag security controls, policies and procedures that functioned sub-optimally and identify ways to improve them. Update the incident response plan accordingly.

Types of incident response teams

The three most common types of incident response teams are as follows:

- Computer security incident response team (CSIRT).
- Computer incident response team (CIRT).
- Computer emergency response team (CERT).

Why is an Incident Response Plan Important?

1. **Minimizing the Impact of Incidents:** A well-structured incident response plan enables organizations to act quickly and efficiently when faced with a cyber threat. By following a predefined set of procedures, organizations can minimize downtime, financial losses, and reputational damage.
2. **Improving Incident Detection:** An effective incident response plan includes continuous monitoring and regular reviews of security systems, which can help organizations detect threats earlier and take proactive measures to prevent breaches.
3. **Streamlining Communication:** A key component of any incident response plan is clear communication among all stakeholders, including IT staff, management, and employees. This ensures that everyone is on

the same page during an incident, reducing confusion and enabling a faster recovery.

4. **Legal and Regulatory Compliance:** Many industries are subject to strict regulations regarding data protection and cybersecurity. Having a well-documented incident response plan in place can help organizations demonstrate their commitment to compliance and avoid potential penalties.
5. **Building Resilience:** Developing and maintaining an incident response plan promotes a culture of security awareness within an organization. As employees become more knowledgeable about potential threats and the proper steps to take during a security incident, the organization as a whole becomes more resilient to cyberattacks.